SECCIÓN 7.5

Inteligencia Artificial aplicada al análisis SOC

Temas de esta sección:

- IA analítica y IA generativa: dos formas distintas de aplicar IA en SOC
- Usos prácticos: resumir, explicar, consultar, generar queries y priorizar
- Lo que la IA puede hacer bien y lo que no debe hacer sola
- Riesgos: alucinaciones, datos sensibles, contexto incompleto, exceso de confianza
- Mini caso: IA explica un comando y qué validación técnica sigue siendo necesaria
- Mini caso: IA dice 'benigno' pero la evidencia posterior dice otra cosa

7.5 | Dos formas de IA en el SOC

IA ANALÍTICA

Modelos que detectan anomalías, clasifican riesgo, calculan scores, agrupan alertas o identifican comportamiento raro.

Ejemplo:
'User risk: High'

Opera sobre datos históricos y estadísticos para generar scores y clasificaciones.

IA GENERATIVA

Modelos que explican, resumen, redactan, generan queries, traducen evidencia o proponen hipótesis.

Ejemplo:
'Resumí esta alerta en lenguaje operativo'

Opera sobre texto e instrucciones para generar respuestas en lenguaje natural.

CRITERIO HUMANO

El analista valida si el output tiene evidencia, contexto, límites y sentido operativo.

La IA acelera, pero no confirma por sí sola.

- ¿El output tiene base en datos reales?
- ¿Hay alucinaciones o generalizaciones?
- ¿La conclusión es coherente con la evidencia?

7.5 | Usos prácticos de IA en análisis SOC

ACELERAR COMPRENSIÓN

- Resumir alertas extensas
- Explicar una línea de comandos
- Traducir logs a lenguaje operativo
- Identificar campos relevantes
- Simplificar evidencia técnica

ASISTIR INVESTIGACIÓN

- Sugerir hipótesis basadas en evidencia
- Proponer fuentes a revisar
- Generar queries iniciales para SIEM/EDR
- Agrupar alertas similares
- Proponer próximos pasos

MEJORAR COMUNICACIÓN

- Redactar escalamientos
- Crear update de estado
- Resumir evidencia para negocio
- Convertir hallazgos técnicos en ticket
- Traducir técnico a operativo

7.5 | Lo que la IA puede hacer vs lo que no debe hacer sola

Puede ayudar a...

- Explicar comandos o logs complejos
- Resumir alertas y eventos relacionados
- Sugerir hipótesis o fuentes a revisar
- Generar queries iniciales para SIEM/EDR
- Redactar tickets, updates o reportes
- Comparar evidencia contra TTPs conocidos
- Traducir hallazgos técnicos a lenguaje de negocio

No debería hacer sola...

Confirmar compromiso sin evidencia directa
Inventar datos que no están en los logs
Ejecutar acciones críticas sin aprobación
Compartir datos sensibles fuera de políticas
Cerrar casos solo por clasificación automática
Reemplazar el criterio del analista
Determinar si hay exfiltración sin evidencia

7.5 | Riesgos de usar IA sin validación

Cuatro riesgos concretos cuando se usa IA sin criterio operativo:

ALUCINACIONES

La IA puede inventar datos, citar fuentes inexistentes o generar outputs que suenan plausibles pero son incorrectos.

Ej: IA genera una explicación de un hash que nunca fue analizado. El analista lo cita como evidencia.

→ Validar siempre el output contra fuentes técnicas reales.

DATOS SENSIBLES

Subir logs, tickets o evidencia con datos de usuarios, IPs internas o información regulada a herramientas de IA no aprobadas puede violar políticas.

Ej: Analista pega logs con cuentas de usuarios en un chat público de IA generativa.

→ Usar solo herramientas aprobadas. Anonimizar antes de pegar evidencia.

CONTEXTO INCOMPLETO

La IA solo ve lo que le pasamos. Sin el contexto completo (proceso padre, horario, ticket, historial), puede dar respuestas incorrectas.

Ej: IA clasifica 'benigno' porque solo vio MFA exitoso, sin la regla de correo posterior.

→ Pasar siempre el contexto completo relevante del caso.

EXCESO DE CONFIANZA

El analista acepta el output de IA sin cuestionar porque parece correcto, autorizado o técnico. Pierde criterio propio.

Ej: IA dice 'Este comando es benigno' y el analista cierra sin revisar process tree.

→ Tratar todo output de IA como hipótesis inicial. Siempre validar.

7.5 | Mini caso: IA explica un comando

La IA puede ayudar a entender, pero la validación sigue siendo técnica:

```
CommandLine:
powershell -nop -w hidden -enc <base64>

Output IA:
"Este comando puede estar asociado a ejecución
oculta y codificada. Podría indicar intento de
evasión o ejecución inicial."
```

Validación necesaria:
Parent process · Usuario · Host · Acción
Archivo creado · Conexiones · Persistencia

Preguntas:

- ¿El output de IA es una conclusión?
- ¿Qué evidencia real lo sostiene?
- ¿Qué no puede saber la IA si no le pasamos contexto?
- ¿Qué fuentes revisarías después?

La IA identifica correctamente que el comando es sospechoso. Pero no sabe quién lo ejecutó, desde qué padre, si hay ticket o actividad posterior. Todo eso lo valida el analista.

7.5 | Mini caso: IA dice 'benigno'

La IA puede equivocarse si no tiene toda la secuencia:

```
Alert: Impossible Travel
IA classification: Likely benign
Reason: MFA Success

Evidencia posterior:
- Device unknown
- Mailbox forwarding rule externa
- OAuth app Read Mail / Read Files
- 1,200 archivos descargados
```

Decisión esperada:

- No confiar solo en la clasificación
- MFA Success no descarta compromiso
- La actividad posterior pesa más que la etiqueta IA
- Escalar a identidad/IR
- Preservar regla, OAuth, sesiones y descargas

La IA clasificó 'Likely benign' porque vio MFA exitoso. Pero no tenía la secuencia completa: regla de reenvío + OAuth + descarga masiva = señales fuertes de compromiso.